VulnScope-AI

Detailed VAPT Lab Assessment Report

Assessment target: http://127.0.0.1:3000

Environment: Local OWASP Juice Shop lab

Assessment approach: Passive HTTP response-header review

Report generated: 2026-10-24 22:19

Assessment status: Preliminary observations; remediation retest not performed

Portfolio project report. This document describes the limited checks performed against the local lab and does not represent a comprehensive penetration test.

1. Executive Summary

VulnScope-AI is a beginner portfolio project that records selected HTTP response observations and produces assessment evidence. A request to the local OWASP Juice Shop target returned HTTP 200 OK. The captured response included X-Content-Type-Options: nosniff and X-Frame-Options: SAMEORIGIN. Content-Security-Policy and Referrer-Policy were not observed in that response. The target was accessed over HTTP in the local lab.

Important: These are limited observations. Missing headers do not, by themselves, prove that an exploitable vulnerability exists. Findings require application-specific review and retesting.

2. Scope and Methodology

In scope

• Local lab target: http://127.0.0.1:3000

• One HTTP response inspected with curl.

• Review of selected response headers and documentation of observations.

Method used

Command used to capture response headers:

```
curl -sS -D evidence/verified-headers.txt -o /dev/null -w "HTTP Status: %{http_code}\n"
http://127.0.0.1:3000
```

Evidence file: evidence/verified-headers.txt. The captured output showed HTTP/1.1 200 OK, X-Content-Type-Options: nosniff, and X-Frame-Options: SAMEORIGIN. The header review did not show CSP or Referrer-Policy in that response.

3. Findings Overview

ID	Observation	Preliminary status
VS-CSP-001	Content-Security-Policy not observed	Needs review
VS-RP-001	Referrer-Policy not observed	Needs review
VS-HTTP-001	Local target accessed over HTTP	Context-dependent

4. Finding Details

VS-CSP-001 — Content-Security-Policy not observed

Severity: Preliminary; determine after further assessment

Observation: The inspected response did not include a Content-Security-Policy (CSP) header.

Potential impact: An appropriate CSP can restrict the sources from which scripts and other resources may load, helping reduce the impact of some injection attacks. Header absence alone does not confirm XSS or exploitability.

Recommendation: Review the application's requirements and configure a suitable CSP. Test it in a staging environment, consider report-only mode during rollout, and verify legitimate functionality before enforcement.

Evidence: evidence/verified-headers.txt. CSP was not observed in the captured response.

Retest: Not performed. Remediation not verified.

VS-RP-001 — Referrer-Policy not observed

Observation: Referrer-Policy was not observed in the captured response.

Potential impact: Without an explicit policy, referrer information may be disclosed according to browser defaults and application context.

Recommendation: Review data-sensitivity and application needs, then configure an appropriate Referrer-Policy, such as strict-origin-when-cross-origin where suitable. Test expected navigation and integrations.

Retest: Not performed. Remediation not verified.

VS-HTTP-001 — Local target accessed over HTTP

Observation: The lab target was requested using http:// rather than HTTPS.

Context and potential impact: Plain HTTP does not provide transport encryption. This is expected in some local training setups, so it should not automatically be treated as a production vulnerability.

Recommendation: For production deployments, use correctly configured HTTPS and verify certificate and transport settings. Keep the lab's local configuration separate from production recommendations.

Retest: Not applicable to the local HTTP-only observation; production TLS was not assessed.

5. Positive Observations

• X-Content-Type-Options: nosniff was present in the inspected response.

• X-Frame-Options: SAMEORIGIN was present in the inspected response.

• The target returned HTTP 200 OK during this check.

6. Limitations

• Only one response from a local lab target was reviewed.

• Other routes and responses may have different headers.

• No comprehensive crawling, authentication testing, source-code review, or exploit validation was performed as part of this header check.

• No XSS vulnerability has been confirmed by this assessment.

• The report is a portfolio learning artifact, not a certification or assurance of application security.

7. Remediation and Retest Checklist

• [ ] Review application security-header configuration.

• [ ] Choose CSP directives appropriate to legitimate application resources.

• [ ] Configure a suitable Referrer-Policy.

• [ ] For production, configure HTTPS and validate TLS.

• [ ] Repeat the header check after changes.

• [ ] Record the date, evidence, and actual retest outcome.

8. Evidence Index

• evidence/verified-headers.txt — captured response headers.

• evidence/header-verification-notes.md — verification notes, if present.

• reports/CSP-Finding.md — detailed CSP observation.

• reports/Remediation-Plan.md — remediation notes.

End of report. Update this document only when new observations or retest evidence are available.